LLM SYSTEM PRIMER

A Governance-First Reference for AI Risk Professionals

AI Security & Governance Learning Track · Week 1, Deliverable 1 of 3

What an LLM is	Architecture components	Deployment patterns & governance vocabulary
How models are trained and what that means for governance	System prompt, context window, RAG, guardrails, agentic tools	Standalone, RAG, agentic — risk profiles and the 4 governance questions

Prepared by: Atinuke Victoria Owete

Target role: AI Governance Architect ·

1. WHAT IS A LARGE LANGUAGE MODEL?

A Large Language Model is a deep learning model — specifically a transformer neural network — trained on massive corpora of text (and increasingly images, code, and audio) to model the statistical relationships between tokens. Understanding what an LLM fundamentally is, and is not, is the foundation of every risk and governance judgment you will make about AI systems.

Concept	What It Means for a Governance Professional
Probabilistic text generator	An LLM does not 'know' things the way a human does. It predicts the next most likely token based on patterns learned from billions of text examples. This means it can be confidently wrong — a fundamental, non-eliminable property. Every governance framework you apply to LLMs must account for irreducible uncertainty in outputs.
Parameter-based knowledge	Knowledge is encoded in billions of numerical parameters (weights) adjusted during training. A 7B-parameter model has 7 billion weights. These weights cannot be 'updated' with new information after training without retraining or fine-tuning — making knowledge cutoff and model freshness a live governance concern.
No memory between sessions	By default, an LLM has no memory of previous conversations. Each session starts fresh. Memory, if present, is an external system — a database, a vector store — attached to the model. This has major implications for continuity of consent, data retention, and GDPR compliance.
No real-time information access	Unless explicitly given tools (web search, database queries), an LLM only knows what was in its training data up to its training cutoff date. Deploying an LLM to answer questions about current regulations, market conditions, or case law without a retrieval layer creates serious accuracy risk.
Pattern matching, not reasoning	Despite appearances, LLMs do not reason — they pattern-match at extraordinary scale. They can produce text that looks like sophisticated reasoning while being subtly wrong. The implication: LLM outputs in high-stakes regulated contexts (credit, AML, medical) require human verification of the reasoning chain, not just the conclusion.
Context-dependent outputs	The same model, given different system prompts or context, will produce dramatically different outputs. This means the risk profile of an LLM deployment is determined not just by the model itself, but by how it is configured, prompted, and constrained. Governance applies to the entire deployment, not just the model.

GOVERNANCE IMPLICATION: The most important property of an LLM for a governance professional is this — it cannot be fully trusted to be correct, even when it sounds certain. Every control you design, every policy you write, and every risk acceptance decision you make about an LLM must be grounded in this fundamental uncertainty.

2. THE LLM TRAINING LIFECYCLE — GOVERNANCE VIEW

Understanding how LLMs are built is not about becoming an engineer. It is about knowing where risk is introduced so you can ask the right questions at each stage. Every stage of the training lifecycle has a corresponding governance obligation — before you even consider what the model does in production.

Stage	What Happens	Risk Introduced	Governance Questions to Ask
1 Data Collection	Raw text, code, images, and other content gathered from the internet, licensed datasets, books, and proprietary sources. Quality and diversity of data largely determines model capability and bias.	Biased, toxic, private, or copyrighted data baked into model weights. GDPR implications if personal data is in the training set. Copyright liability for training on unlicensed content.	What data sources were used? Was personal data included? Is there a data lineage document? Was the data licensed for AI training?
2 Data Preprocessing & Filtering	Raw data is cleaned, deduplicated, filtered for quality and safety, and tokenised. Toxic or harmful content is removed (or attempted to be removed). Data is formatted for training.	Filtering failures leave harmful content in the training set. Over-filtering removes minority group representation, introducing bias. The filtering process itself is opaque.	What quality and safety filtering was applied? Is the filtering methodology documented? Was the filtered dataset validated for demographic representation?
3 Pre-Training	The model learns statistical patterns across the entire training corpus by predicting masked or next tokens. This stage requires enormous compute and produces the 'base model' — capable of generating coherent text but not yet aligned to any specific task or safety standard.	The base model will generate almost anything — it has no task alignment, no safety constraints, and no instruction-following capability. Base models are never deployed directly to end users without further training.	Is this a base model or an instruction-tuned model? What safety training was applied after pre-training? Who conducted the safety evaluation?
4 Fine-Tuning (Instruction Tuning)	The base model is trained on a curated dataset of (instruction, ideal response) pairs to teach it to follow instructions, answer questions, and refuse harmful requests. This produces an 'instruction-tuned' model.	The fine-tuning dataset can introduce new biases, backdoors, or capability limitations. If the fine-tuning data is low quality or misaligned, the model's behaviour can degrade in subtle, hard-to-detect ways.	Who created the fine-tuning dataset? What quality control was applied? Was the fine-tuned model evaluated against the base model for capability regression? Who has access to the fine-tuning data?
5 RLHF (Reinforcement Learning from Human Feedback)	Human raters score model outputs for quality, safety, and helpfulness. A 'reward model' is trained on these ratings. The main model is then further trained to maximise the reward model's score. This is the primary alignment technique used by OpenAI, Anthropic, Google, and Meta.	Sycophancy: the model learns to say what raters prefer, not what is true or most accurate. Rater demographics and instructions shape the model's values in ways that may not be transparent. Cultural biases in the rater pool can propagate into the model.	Who were the human raters? What guidelines were they given? Were raters demographically diverse? How were edge cases and cultural disagreements handled? Is the reward model itself evaluated for bias?
6 Evaluation & Red-Teaming	The trained model is evaluated on benchmark datasets and red-teamed by human adversarial testers to identify safety failures, jailbreaks, and capability risks before deployment.	Red-teaming is inherently incomplete — it finds the failures the testers think to look for, not all possible failures. Models often pass benchmarks while failing in deployment contexts that weren't tested.	What evaluation benchmarks were used? Were they representative of the deployment context? Who conducted red-teaming? What was the scope? What failure modes were found and how were they addressed?
7 Deployment	The model is served via API, embedded in a product, and accessed by end users. Deployment configurations (system prompt, guardrails, retrieval layer, tool access) are determined at this stage.	The deployment configuration determines the actual risk profile. A well-trained model can be dangerously deployed. A model with some safety limitations can be safely deployed with the right guardrails. Risk lives in the deployment configuration as much as the model itself.	Who controls the deployment configuration? Is the system prompt reviewed as part of a governance process? Are deployment changes subject to change management and risk assessment?

8 Production Monitoring	Model outputs are sampled and monitored for drift, hallucination rates, policy violations, anomalous usage patterns, and degradation in accuracy over time.	Silent failures: model drift or performance degradation can go undetected for months without adequate monitoring. Monitoring gaps create audit evidence problems — you cannot prove the model was behaving appropriately if you were not watching.	What metrics are monitored? What are the alert thresholds? Who is notified when an alert fires? What is the incident response process? Is monitoring evidence retained for the period required by DORA and the EU AI Act?

KEY INSIGHT FOR GRC PROFESSIONALS: Most AI governance frameworks focus on deployment-time risk. The training lifecycle shows why pre-deployment risk is equally critical. A biased training dataset, inadequate red-teaming, or poor RLHF rater quality can produce a model that passes all pre-deployment checks and still causes harm at scale in production. Your governance framework must cover the full lifecycle, not just the deployment gate.

3. LLM ARCHITECTURE COMPONENTS

An LLM deployment is not just a model. It is a system of interconnected components, each with its own risk profile and governance obligations. Understanding each component — what it does, what can go wrong, and what you need to control — is the prerequisite for any meaningful AI risk assessment.

System Prompt

WHAT IT IS

The system prompt is a set of instructions provided to the model before any user interaction begins. It defines the model's persona, its scope of operation, what it is allowed and not allowed to do, and any confidential context it needs to function. The user does not see it; the model treats it as its operating instructions.

RISKS

→ System prompt injection: a user crafts input that convinces the model to ignore or reveal the system prompt

→ System prompt extraction: through careful probing, a user reconstructs the confidential contents of the system prompt

→ Prompt leakage in error messages or debug outputs

GOVERNANCE ACTIONS

✓ The system prompt must be treated as a confidential trade secret at the same classification level as other proprietary business logic

✓ Changes to the system prompt must be subject to change management — it is a configuration change with risk implications

✓ Test regularly: can a user extract the system prompt? Does the model follow the system prompt's restrictions under adversarial prompting?

✓ System prompt should define explicit escalation instructions: 'If the user asks about X, respond with Y and do not attempt to answer'

Context Window

WHAT IT IS

The context window is the total amount of text the model can process in a single inference call — including the system prompt, conversation history, any retrieved documents, and tool outputs. Modern models range from 8,000 to 200,000+ tokens (roughly 6,000 to 150,000 words). Everything the model 'knows' in a given interaction must fit within this window.

RISKS

→ Context overflow: when the window is full, older content is silently truncated — the model may lose critical context without warning

→ Cross-session contamination: in poorly implemented systems, one user's context bleeds into another user's session

→ PII in context: if retrieved documents or prior messages contain personal data, it is exposed to the model (and its logs) for the duration of the session

→ Data retention: what is in the context window at any moment may constitute processing of personal data under GDPR

GOVERNANCE ACTIONS

✓ Monitor context size at assembly time — alert when approaching the limit

✓ Implement strict session isolation: no context should persist or leak between user sessions

✓ Classify context window contents: if the context includes personal data, the retention and processing obligations of GDPR Article 6 apply

✓ Logging of context window contents may be required for incident investigation but creates its own data protection obligations — balance these explicitly

Retrieval Layer (RAG)

WHAT IT IS

Retrieval Augmented Generation (RAG) connects the model to a live knowledge base — internal documents, databases, policy repositories — queried at runtime. When a user asks a question, relevant document chunks are retrieved and injected into the context window before the model generates a response. This dramatically improves accuracy for domain-specific tasks

RISKS

→ Indirect prompt injection: malicious instructions embedded in retrieved documents override the system prompt

→ Unauthorised document access: user retrieves chunks from documents they should not be able to see

→ Context poisoning: an attacker plants corrupted documents in the knowledge base

→ Stale retrieval: out-of-date documents cause confidently incorrect answers

GOVERNANCE ACTIONS

✓ Document-level access controls: user identity must be propagated to the retrieval query — retrieval scope must match user authorisation

✓ Treat all retrieved content as untrusted input: retrieved text should never be able to override system prompt instructions

✓ Knowledge base ingestion controls: who can add documents? What review process exists before documents enter the retrieval pool?

✓ Document versioning and expiry: implement metadata so outdated documents are flagged or retired

and reduces hallucination on factual questions.

Inference Engine

WHAT IT IS

The inference engine is the compute infrastructure that runs the model and returns outputs. For hosted models (OpenAI GPT-4, Anthropic Claude, Google Gemini), inference happens on the vendor's infrastructure. For self-hosted models, inference runs on the organisation's own GPU infrastructure, often in a cloud environment.

RISKS

→ Data residency: for hosted models, inference inputs and outputs may be processed in jurisdictions that conflict with GDPR or data sovereignty requirements

→ Inference logging by the vendor: the vendor may log your inputs and outputs for model improvement, safety review, or legal compliance — without explicit disclosure

→ Performance dependencies: inference latency affects real-time use cases (fraud detection, AML alerts) — SLA failures here may constitute DORA incidents

→ Cost and resource abuse: uncontrolled inference costs can escalate rapidly under adversarial or misuse scenarios

GOVERNANCE ACTIONS

✓ Data processing agreements: for any hosted model, you must have a DPA in place that covers inference data as personal data processing under GDPR

✓ Review the vendor's data retention and logging policies: what inputs and outputs are logged? For how long? For what purpose?

✓ Latency SLAs: define and monitor inference latency requirements for any real-time regulated use case

✓ Cost monitoring and alerting: set spend thresholds and alert on anomalous usage patterns

Output Filters / Guardrails

WHAT IT IS

Guardrails are post-processing layers that intercept model outputs before they reach the user. They may block harmful, off-topic, or policy-violating content; detect and redact PII; enforce output format compliance; or route specific outputs to human review. Guardrails are your primary application-level control layer — but they are not infallible.

RISKS

→ Guardrail bypass: adversarial inputs can be crafted to produce harmful outputs that evade detection (e.g. encoding harmful content in a fictional framing, using a different language, or splitting a request across multiple turns)

→ Over-refusal: overly aggressive guardrails block legitimate queries, degrading product utility and pushing users to find workarounds

→ False confidence: the existence of guardrails creates a perception of safety that may not reflect actual risk reduction — guardrails that haven't been adversarially tested provide false assurance

GOVERNANCE ACTIONS

✓ Guardrails must be adversarially tested as part of every deployment gate — not just tested on benign inputs

✓ Track refusal rates: anomalous spikes may indicate a jailbreak campaign; high baseline rates may indicate over-tuning

✓ Guardrail bypass attempts must be logged as security events and reviewed — they are your leading indicator of adversarial activity

✓ Guardrails are a compensating control, not a primary control. Do not design governance frameworks that treat guardrails as the sole risk mitigation for high-stakes use cases

Memory & Tool Calls

WHAT IT IS

In agentic AI systems, the model can be given tools that allow it to take actions in the world: web search, email, calendar, database reads/writes, code execution, file management, API calls, and more. Memory systems allow the model to retain information across sessions. These capabilities transform the model from a text generator into an autonomous agent — with a fundamentally different risk profile.

RISKS

→ Autonomous harmful actions: the model can take irreversible actions (send emails, delete records, execute payments) without human review if tool calls are not gated

→ Privilege escalation: a model with email and calendar access can leak confidential information to external parties

→ Tool call injection: prompt injection via a retrieved document can instruct the model to call a tool in an unintended way

→ Audit trail gaps: if tool calls are not logged with full context, you cannot reconstruct what the model did and why — creating regulatory compliance problems

GOVERNANCE ACTIONS

✓ Least privilege: each tool should have the minimum permissions required for its stated purpose — treat tool permissions like RBAC

✓ Human-in-the-loop gates: for any irreversible or high-impact action, require explicit human confirmation before execution

✓ Complete audit logging: every tool call, its input parameters, its output, and the model's stated reason for calling it must be logged

✓ Test tool call boundaries: can a user craft input that causes the model to call a tool with unintended parameters? This is tool call injection testing

4. DEPLOYMENT PATTERNS — RISK PROFILES

The risk profile of an LLM deployment is determined primarily by how the model is configured and connected, not by the model itself. A powerful model deployed with appropriate constraints can be lower risk than a simple model deployed carelessly. Understanding these four deployment patterns is the foundation of your pre-deployment risk assessment.

Standalone LLM

Internal knowledge assistants, general-purpose chat tools (ChatGPT, Claude.ai), writing assistance, summarisation tools.

User interacts directly with the model through a chat interface. No external data retrieval, no tool calls, no persistent memory. The model draws exclusively on its training knowledge.

RISK
LOW — MEDIUM

Risk Profile

Hallucination is the primary risk. The model may confidently state incorrect information. Without retrieval, the model's knowledge is limited to its training cutoff date. Jailbreak and harmful output risk is present but contained — no external data or systems are connected.

Key Controls

- ✓ Output disclaimers for high-stakes queries
- ✓ Human review for regulated decisions
- ✓ Rate limiting and abuse monitoring
- ✓ Clear scope documentation — users must understand the model has no access to current data

GOVERNANCE NOTE: Simplest deployment pattern to govern. Risk is largely contained within the conversation. Primary concern is overreliance — users treating LLM outputs as authoritative without verification.

RAG-Augmented LLM

Enterprise document Q&A, internal policy search, customer service bots drawing on knowledge bases, regulatory filing assistants, due diligence tools.

The model is connected to an internal knowledge base. At query time, relevant document chunks are retrieved and injected into the context window before the model generates a response. Dominant enterprise deployment pattern.

RISK
MEDIUM — HIGH

Risk Profile

Significantly higher attack surface than standalone. Indirect prompt injection via retrieved documents is the primary security risk. Unauthorised document access via the retrieval layer is the primary data governance risk. Citation accuracy (does the response actually reflect the retrieved source?) is a regulated-context compliance risk.

Key Controls

- ✓ Document-level ACLs in the retrieval layer
- ✓ Sanitisation of retrieved content before context assembly
- ✓ Citation verification — every factual claim must trace to a retrieved source
- ✓ Knowledge base ingestion governance — who can add documents?
- ✓ Session isolation testing

GOVERNANCE NOTE: The retrieval layer is effectively a new attack surface that most security frameworks do not adequately cover. Your TPRM questionnaire for RAG systems must include questions about the retrieval layer's access controls, not just the model itself.

Agentic LLM

AI coding assistants that submit code, AI email assistants that draft and send, AI financial assistants that query live data and execute trades, multi-agent research pipelines, autonomous process automation.

The model can take autonomous actions in the world: browse the web, call APIs, execute code, send emails, manage files, interact with databases. Often operates as multi-step workflows with minimal human oversight. The fastest-growing deployment category in 2025.

RISK
HIGH — CRITICAL

Risk Profile

Qualitatively different risk profile from all other deployment patterns. The model can cause irreversible external harm — emails sent, records deleted, payments executed, code deployed. DORA operational resilience obligations are directly implicated. EU AI Act high-risk classification is likely for agentic AI in regulated financial contexts.

Key Controls

- ✓ Human-in-the-loop gates for all irreversible actions
- ✓ Least-privilege tool permissions — no tool has more access than strictly needed
- ✓ Complete audit logging of every tool call with context
- ✓ Scope limitation — explicit allowed/denied action lists
- ✓ Adversarial testing of tool call injection scenarios
- ✓ Incident response plan for autonomous action failures

GOVERNANCE NOTE: Agentic AI is where most organisations do not yet have adequate governance. This is also where the EU AI Act's high-risk classification is most likely to apply in financial services. If your organisation is deploying or evaluating agentic AI, it should be subject to your full pre-deployment governance gate, not a lightweight review.

Multi-Model Pipeline

Document processing pipelines (classify → extract → summarise → route), fraud detection (feature extraction → classification → explanation → alert generation), customer onboarding (document OCR → data extraction → risk scoring → decision).

Multiple AI models are chained together in a workflow: one model classifies input, another generates content, another validates output, another takes action. Each model's output becomes the next model's input. Common in complex enterprise AI deployments.

RISK
HIGH

Risk Profile

Emergent risk from model interactions: a small error in early stages compounds through the pipeline. Accountability gaps: when a pipeline produces a harmful output, it can be unclear which component is responsible. Audit trails must cover the entire pipeline, not individual components.

Key Controls

- ✓ End-to-end pipeline testing, not just component testing
- ✓ Output validation between pipeline stages — each stage should validate its input before processing
- ✓ Single accountability owner for the pipeline's risk posture
- ✓ Pipeline-level audit logging that captures the full data flow
- ✓ Failure mode analysis: what happens when each stage fails?

GOVERNANCE NOTE: Multi-model pipelines are where systems thinking becomes critical. You must model the pipeline as a

system, not a collection of independent components. Your risk assessment must ask: what are the feedback loops, cascade failure paths, and emergent risks when these components interact at scale?

5. GOVERNANCE VOCABULARY — 15 TERMS YOU WILL USE DAILY

These are the terms you need to use fluently in conversations with AI engineers, product teams, and boards. For each term, the governance implication column tells you why it matters beyond the technical definition — what it means for your risk assessment, your audit findings, and your regulatory conversations.

Term	Definition	Why It Matters for AI Governance
Hallucination	A model generates a confident, plausible-sounding output that is factually incorrect. The model does not 'know' it is wrong — it is generating the statistically most likely next tokens, not accessing verified facts.	In a regulated context, a hallucinated credit score, compliance ruling, or legal interpretation looks identical to a correct one. Detection requires external verification, not model self-assessment. You cannot ask the model 'are you sure?' and trust the answer.
Prompt Injection	A form of attack in which malicious instructions are embedded in user input or retrieved content, causing the model to override its system prompt and take unintended actions.	Your primary application-layer security threat. Think of it as SQL injection for LLMs — except instead of executing database queries, the injected instruction can cause the model to exfiltrate data, take autonomous actions, or bypass safety controls.
Grounding	The process of anchoring a model's response to specific, verifiable source documents — typically through RAG. A 'grounded' response is one where every factual claim can be traced to a retrieved source.	Grounding is your primary tool for reducing hallucination in high-stakes contexts. Your governance framework for any RAG deployment should require that regulated outputs be grounded — with citations that are verified to accurately reflect the source document.
Ground Truth	The verified correct answer used to evaluate model performance. In a production context, ground truth is established by human experts reviewing model outputs against known-correct data.	When a model produces outputs for regulated decisions (credit, AML, fraud), establishing ground truth is how you determine whether the model is performing adequately. Without ground truth, you cannot measure model accuracy — you have a governance gap.
Inference	The production process by which a deployed model takes input and produces output. Inference is distinct from training — it is the operation of the model, not the building of it.	Most production risk lives at inference time — not in the training process. Prompt injection, hallucination, data leakage, and guardrail bypass all occur at inference. Your monitoring and control framework must focus primarily on inference-time behaviour.
Fine-Tuning	Retraining a pre-trained base model on a curated domain-specific dataset to adapt its behaviour for a specific task, persona, or knowledge domain.	Fine-tuning creates new data governance obligations: who owns the fine-tuning data? Was personal data used? If fine-tuning data is leaked or extracted, what are the consequences? Fine-tuned models should be subject to the same governance gate as any new AI deployment.
Model Drift	The degradation of a model's performance over time as the real-world data distribution diverges from the training data distribution. Drift can be sudden (an external event changes user behaviour) or gradual (language and concepts evolve).	A model that is accurate at deployment may become dangerously inaccurate six months later without any changes to the model itself. Continuous monitoring for drift is not optional — it is a DORA operational resilience requirement and an EU AI Act ongoing obligation for high-risk AI systems.
Context Window	The total amount of text a model can process in a single inference call, measured in tokens (roughly 0.75 words each). Modern models range from 8,000 to 200,000+ tokens.	Context window size limits create a silent truncation risk: when the window is full, older content is dropped without warning. In a multi-turn conversation, this means the model may 'forget' critical context — including safety instructions injected early in the conversation.
Token	The unit of text that LLMs process. Roughly equivalent to 0.75 English words. Most LLM pricing and context window limits are expressed in tokens.	Adversaries use knowledge of tokenisation to craft inputs that bypass filters (splitting words in ways that defeat detection) or to manipulate model behaviour at a sub-word level. Understanding that the model processes tokens, not words, helps you understand certain classes of adversarial inputs.
Temperature	A parameter that controls the randomness of model outputs. Temperature 0 = deterministic (always the most likely next token). Temperature 1+ = increasingly random and creative.	High temperature settings increase both creativity and hallucination rate. For regulated use cases requiring factual accuracy (compliance Q&A, AML decision support), temperature should be set low. For creative use cases (marketing copy, brainstorming), higher temperature is appropriate. Temperature is a governance-relevant configuration parameter.

Guardrails	Input and output processing layers that detect and block harmful, off-topic, or policy-violating content. Guardrails can be rule-based (keyword filters), model-based (a separate classifier evaluates the output), or both.	Guardrails are a compensating control — they reduce risk but do not eliminate it. Adversarial inputs can bypass guardrails. Over-reliance on guardrails as your sole safety mechanism is a governance failure. Test guardrails adversarially before deployment and re-test after any change to the model or prompt.
Embeddings	Dense numerical vector representations of text used in RAG systems to measure semantic similarity between a query and documents in the knowledge base.	The embedding model is a component of your RAG system that is often overlooked in governance reviews. If the embedding model is updated or changed, the semantic relationships between queries and documents change — potentially causing retrieval to return different documents, silently degrading retrieval quality.
Agentic AI	An AI system that can take sequences of actions autonomously to achieve a goal, including calling external tools, managing files, browsing the web, and interacting with other AI models.	Agentic AI represents a qualitatively different risk category from conversational AI. The model can cause irreversible external harm. Under the EU AI Act, agentic AI systems used in regulated financial services contexts are likely to be classified as high-risk, triggering the full conformity assessment and ongoing monitoring requirements.
System Prompt	The configuration instructions provided to the model before any user interaction begins. Sets the model's persona, scope, prohibited topics, and operating rules. Not visible to the end user.	The system prompt is effectively the access control policy for your AI deployment. It must be reviewed as a governed configuration — not a developer convenience. Changes to the system prompt should go through your standard change management process, including risk assessment.
RAG (Retrieval Augmented Generation)	An architecture in which a model is connected to a live knowledge base, retrieving relevant document chunks at query time to ground its responses in domain-specific, current information.	RAG is the dominant enterprise AI deployment pattern. Your governance framework must specifically address RAG-specific risks: indirect prompt injection, unauthorised document retrieval, knowledge base provenance, and citation accuracy. A governance framework written for standalone LLMs does not adequately cover a RAG deployment.

6. THE FOUR GOVERNANCE QUESTIONS

Every AI system assessment you conduct, every board presentation you give, and every regulatory conversation you have will ultimately map back to four questions. These questions are the organising framework of your AI governance practice. Memorise them. Every audit finding, every risk acceptance decision, and every incident response action you take will be an answer to one of them.

Q1: What data went in?

What data was used to train this model, to fine-tune it, and to populate its retrieval knowledge base? Is that data appropriate for this use case under GDPR, EU AI Act Article 10, and ISO 42001?

WHY THIS QUESTION: The inputs to an AI system determine its capabilities, its biases, and its legal exposure. A model trained on data containing personal data without adequate consent, or fine-tuned on confidential client data without appropriate data processing agreements, creates regulatory liability that cannot be retroactively fixed.

AUDIT CHECKS

- ✓ Is there a data lineage document for the training data?
- ✓ Was personal data included in training or fine-tuning? Under what lawful basis?
- ✓ Has the knowledge base been vetted for accuracy, bias, and authorisation?
- ✓ Is there a data expiry and refresh policy for the retrieval layer?
- ✓ Does the training/fine-tuning data use trigger any GDPR Article 30 processing records obligations?

Q2: What can the model do autonomously?

What actions can this model take without human review — and are there adequate controls on those actions? This question applies both to direct outputs (can it produce harmful content?) and to tool calls (can it send emails, execute payments, or delete records?).

WHY THIS QUESTION: The risk profile of an AI deployment scales directly with the model's capacity for autonomous action. A model that only generates text has a contained risk profile. A model that can call APIs, browse the web, and manage files has a risk profile comparable to a privileged human user — and should be governed accordingly.

AUDIT CHECKS

- ✓ What tools does the model have access to? Are they documented?
- ✓ Is there a least-privilege policy for tool access?
- ✓ What actions require human approval before execution?
- ✓ Can the model take irreversible actions? What is the reversal procedure if it makes an error?
- ✓ Are all tool calls logged with sufficient context for incident investigation?

Q3: What happens when the model is wrong?

When this model produces an incorrect, harmful, or policy-violating output — and it will, eventually — who is accountable? What is the detection mechanism? What is the notification path? Who is the named individual responsible for AI risk decisions under DORA, the EU AI Act, and your organisation's governance framework?

WHY THIS QUESTION: AI systems will fail. The question is not whether but how and when. Organisations that have not pre-defined accountability, detection, notification, and remediation for AI failures will face a worse regulatory and reputational outcome when failures occur than organisations that have. Accountability must be human and named — not diffuse.

AUDIT CHECKS

- ✓ Is there a named AI risk owner for this deployment?
- ✓ What is the AI incident classification framework? What constitutes a 'major' incident under DORA?
- ✓ What are the regulatory notification timelines? (EU AI Act Article 73: serious incidents; DORA: ICT-related incidents)
- ✓ What is the model rollback or disable procedure?
- ✓ How are affected users identified and notified after an AI-caused harm?

Q4: How do we know it is still working?

What ongoing monitoring exists to detect model drift, performance degradation, emerging failure modes, and changing risk profiles? How frequently is the model evaluated against ground truth? What triggers a formal re-assessment or re-deployment review?

WHY THIS QUESTION: AI systems are not static. A model that performs well at deployment can degrade silently over months as real-world usage patterns, language, and external conditions change. Continuous monitoring is not a technical nice-to-have — it is an explicit obligation under DORA operational resilience requirements and EU AI Act Article 61 for high-risk AI systems.

AUDIT CHECKS

- ✓ What metrics are monitored in production? At what frequency?
- ✓ What drift detection thresholds trigger a model review?
- ✓ Is there a scheduled periodic re-evaluation of the model against ground truth?
- ✓ Who reviews monitoring data, and at what cadence?
- ✓ Is monitoring evidence retained for the period required by DORA (5 years) and the EU AI Act?

HOW TO USE THESE QUESTIONS IN PRACTICE: When a product team brings you a new AI use case for governance review, these four questions are your intake form. You do not need a 40-page questionnaire to start. Ask Q1 through Q4, require evidence for each answer, and use the gaps as the foundation of your risk assessment. Any gap in any of the four questions is a finding that requires a control or a formal risk acceptance.

7. REGULATORY FRAMEWORK MAPPING

Every LLM deployment you govern sits at the intersection of multiple regulatory frameworks. Understanding how each framework applies to LLM-specific scenarios — and what your governance obligations are under each — is what allows you to speak with authority to regulators, boards, and product teams.

Framework	Scope	Key Articles / Sections	LLM-Specific Impact	Your Governance Role
EU AI Act (2024)	All AI systems deployed in the EU or affecting EU persons. Prohibited uses absolute; high-risk systems require conformity assessment before deployment.	Art. 5 (prohibited), Art. 6–7 (high-risk classification), Art. 9 (risk management), Art. 10 (data governance), Art. 13 (transparency), Art. 61 (post-market monitoring), Art. 73 (incident reporting)	General-purpose AI models (GPAIs) like GPT-4 and Claude are directly regulated under Articles 51–56. Deployers of high-risk AI systems carry obligations even when using third-party models.	You own the conformity assessment process, the risk management documentation, and the post-market monitoring programme for any high-risk AI deployment in your organisation.
DORA (Digital Operational Resilience Act)	Financial entities in the EU. Covers ICT risk management including AI-related operational risk.	Art. 6 (ICT risk management), Art. 10 (detection), Art. 17–20 (incident management), Art. 28–30 (third-party risk)	AI system failures that cause operational disruption are ICT incidents under DORA. Third-party AI providers (OpenAI, Anthropic, Microsoft) are ICT third-party service providers subject to DORA's concentration risk provisions.	AI systems must be in scope for your ICT risk management framework. AI provider contracts must include DORA-compliant terms. AI incidents must be classified and reported under your DORA incident management process.
GDPR (General Data Protection Regulation)	Processing of personal data in the EU or of EU persons anywhere in the world.	Art. 5 (principles), Art. 6 (lawful basis), Art. 9 (special categories), Art. 22 (automated decision-making), Art. 30 (records), Art. 35 (DPIA), Art. 83 (fines)	Training data containing personal data, inference inputs containing personal data, and outputs revealing personal data are all GDPR-regulated processing activities. Article 22 creates specific obligations for automated decisions with legal or significant effects.	AI-specific DPIAs for high-risk processing activities. Article 22 assessment for any automated decision-making use case. DPA review for hosted AI providers. Data minimisation enforcement for inference inputs.
ISO/IEC 42001:2023	Voluntary international standard for AI management systems. Increasingly referenced by regulators and procurement requirements.	Clause 6 (planning and AI risk), Clause 8 (operations and AI policy), Clause 9 (performance evaluation), Clause 10 (improvement)	Provides a systematic framework for AI risk management that maps directly to your existing ISO 27001 management system. Most EU financial regulators are beginning to reference ISO 42001 in their AI supervisory expectations.	You hold the ISO 42001 Lead Implementer certification. You are the qualified owner of an AI management system that covers the full AI lifecycle — from use case approval to post-deployment monitoring.
NIST AI RMF 1.0	US voluntary framework increasingly adopted globally, including by Canadian and some EU regulators as a reference.	GOVERN (culture and accountability), MAP (risk identification), MEASURE (risk analysis), MANAGE	The most operationally detailed AI governance framework available. The GOVERN function maps directly	Use NIST AI RMF as your operational framework where the EU AI Act does not provide

		(risk treatment and monitoring)	to your board and executive reporting obligations. The MAP-MEASURE-MANAGE cycle maps to your risk register management.	implementation-level detail. The AI RMF Playbook gives specific suggested actions for each function that you can translate directly into control requirements.

PRACTICAL NOTE: In EU financial services, you will typically be operating under all five frameworks simultaneously. The EU AI Act is the primary AI-specific regulation. DORA governs operational resilience. GDPR covers personal data processing. ISO 42001 provides the management system structure. NIST AI RMF provides operational implementation detail. Your AI governance framework must be designed to satisfy all five — which is possible, because they are largely complementary, not contradictory.

LLM SYSTEM PRIMER

ADDENDUM — Sections 8–15

What an LLM is and is not · Output generation and auditability · Deployment patterns · Data flow · Risk concentration · Control themes · Evidence framework · Extended glossary

These sections extend the LLM System Primer with content from the AI Security & Governance Learning Track reference document. They use the same structure, colour coding, and governance framing as Sections 1–7.

8. WHAT AN LLM IS — AND WHAT IT IS NOT

A Large Language Model is a statistical text generation system trained on large corpora to predict the next token given prior tokens. That definition — deceptively simple — contains everything a governance professional needs to understand about why LLMs require a fundamentally different assurance approach to traditional software systems.

What LLMs are genuinely good at

Good at	What this means in practice
Summarising	Condensing long documents, reports, or conversations into shorter, structured summaries. Reliable when the source material is in the context window.
Drafting	Generating first-draft text (emails, policies, reports, code) that a human then reviews and finalises. Speed advantage is real; accuracy verification is still required.
Classifying	Categorising text into predefined categories (e.g. sentiment, topic, intent). Performance depends heavily on training and prompt design.
Extracting	Pulling structured information from unstructured text (entities, dates, amounts, relationships). Useful for ingestion pipelines with human spot-checks.
Transforming	Converting text from one format to another (e.g. JSON to prose, bullet points to narrative, language translation). Generally reliable for format transformations.
Generating plausible responses	Producing contextually appropriate, fluent text that fits the conversation. The plausibility of the response is independent of its factual accuracy.

What LLMs are NOT — with governance implications

It is NOT	Governance and security implication
A database of verified facts	The model has no access to a truth store. It generates the most statistically likely next token given its training — which means it can produce convincingly wrong answers with equal confidence to correct ones. SECURITY IMPLICATION: Never use raw LLM output as a source of truth for regulated decisions without independent verification or retrieval grounding.
A deterministic rules engine	The same input can produce different outputs across runs, especially at higher temperature settings. SECURITY IMPLICATION: You cannot 'test once and certify forever.' Governance of LLM outputs requires ongoing monitoring, sampling, and periodic re-evaluation — not a point-in-time assessment.
A reasoning authority with guaranteed correctness	LLMs perform pattern-matched approximations of reasoning. They can produce outputs that look like rigorous analysis while containing subtle logical errors or unsupported conclusions. SECURITY IMPLICATION: For any LLM output that informs a regulated decision, the reasoning chain must be independently validated — not just the conclusion.
Automatically compliant with your policies	Without explicit system prompt constraints, guardrails, monitoring, and user controls, an LLM will generate whatever is statistically likely — including content that violates your policies, regulatory obligations, or ethical standards. SECURITY IMPLICATION: Compliance is not a property of the model; it is an outcome of your entire deployment architecture and governance framework.

FOUNDATIONAL GOVERNANCE PRINCIPLE: Treat all LLM output as untrusted unless it is validated through one or more of the following: (a) grounded in a RAG layer with approved, access-controlled sources; (b) verified by a human expert with documented sign-off; or (c) validated by a secondary system (another model, a rules engine, or a factual verification service). Raw LLM output going directly into a regulated decision, external communication, or operational action is a governance gap.

9. HOW LLM OUTPUTS ARE GENERATED — AUDITABILITY IMPACT

Understanding how LLM outputs are generated is not a technical exercise for engineers — it is a prerequisite for designing a governance framework that can actually demonstrate control effectiveness to regulators and auditors. The generation mechanism determines what 'consistent, auditable, repeatable' means for an AI system — and it is fundamentally different from what it means for traditional deterministic software.

Core generation concepts and their governance implications

Concept	What it is	Governance and auditability implication
Tokens	LLMs process text as tokens — chunks of characters that may be shorter or longer than a word. 'Governance' is 1 token; 'anti-disestablishmentarianism' might be 5. The model operates entirely at the token level — it has no concept of 'words', 'sentences', or 'meaning'.	Adversarial inputs can exploit tokenisation to bypass filters. A word split across tokens may not match a prohibited-word list that operates at the character level. Sensitive data detection must account for tokenisation boundaries.
Context window	The total text the model can 'see' during a single inference call — system prompt + conversation history + retrieved documents + tool outputs. Modern models range from 8,000 to 200,000+ tokens.	Sensitive data placed anywhere in the context window is visible to the model and may be reproduced in outputs. Long contexts can dilute or bury system prompt control instructions — a 200-page document retrieved into context may effectively override a 200-word system prompt in terms of model attention.
Temperature	A parameter (0 to 2+) controlling output randomness. Temperature 0 = the model always selects the highest-probability next token. Temperature 1+ = the model samples from a broader probability distribution, producing more varied, creative, and unpredictable outputs.	Higher temperature = lower repeatability = harder to demonstrate consistent control outcomes. For regulated use cases (compliance guidance, risk assessments), temperature should be set low (0–0.3) and documented as a governance-relevant configuration parameter.
Top-p (nucleus sampling)	An alternative to temperature that restricts the model to choosing from only the top-p% of probability mass. Top-p of 0.1 means the model only considers the 10% most likely tokens at each step. Often used in combination with temperature.	Like temperature, top-p affects output consistency and auditability. Must be documented alongside temperature as part of model configuration governance. Changes to either parameter should go through change management.
Sampling at each token	The model generates output token-by-token, with each token selection influenced by all previous tokens in the context. This means output is path-dependent — early token choices shape all subsequent choices.	The same input prompt can produce different outputs on sequential runs unless temperature = 0 (fully deterministic). For audit and testing purposes, document whether deterministic settings are required, and test at the actual production temperature settings — not at temperature 0.

Auditability impact by generation characteristic

Generation characteristic	Effect on outputs	Auditability implication	Control requirement
Higher randomness (high temperature/top-p)	Reduces repeatability — the same input produces different outputs	Cannot 'test once and certify'. Continuous monitoring is required. Test at production temperature settings, not deterministic settings.	**ONGOING MONITORING REQUIRED**
Deterministic settings (temp=0)	Same input always produces same output	Improves reproducibility but does not guarantee factual correctness. A deterministic hallucination is still a hallucination.	**TEST WITH ADVERSARIAL INPUTS**
Long context windows	More information available to the model	System prompt instructions may be diluted. Sensitive data from retrieved documents persists in context for the session duration.	**CONTEXT HYGIENE CONTROLS REQUIRED**
Tool/function calling	Model can take external actions	Actions taken by the model must be logged as if taken by a user — they have operational and audit significance equivalent to a privileged user action.	**FULL AUDIT LOGGING MANDATORY**

Streaming outputs	Response delivered token-by-token before complete	Cannot apply output filtering to a partial response. Guardrails must be designed to work on streaming output or applied post-completion.	**GUARDRAIL ARCHITECTURE IMPACT**

OPERATIONAL GUIDANCE FOR REGULATED USE CASES: For any AI deployment used in a regulated context, document all generation parameters (temperature, top-p, max tokens) as governed configuration items. Changes to these parameters must go through your standard change management process — they materially affect output consistency and the auditability of control outcomes. Run acceptance testing at production parameter settings. Do not certify a deployment tested at temperature 0 that will run at temperature 0.7 in production.

10. ENTERPRISE DEPLOYMENT PATTERNS — RISKS AND CONTROLS

The risk profile of any AI deployment is determined primarily by its architecture — how the model is connected to data, systems, and users. Five core deployment patterns cover the vast majority of enterprise AI deployments. Each has a distinct risk profile and requires a tailored set of controls.

API MODEL (VENDOR-HOSTED LLM)

Your application sends prompts directly to a provider API (OpenAI, Anthropic, Google, Cohere) and receives outputs. The model infrastructure, compute, and serving are entirely managed by the vendor. Your organisation controls the application layer, system prompt, and how outputs are used.

Examples: OpenAI GPT-4 via API, Anthropic Claude API, Google Gemini API, Azure OpenAI Service, AWS Bedrock.

KEY RISKS

→ Third-party data processing
All inputs (including sensitive data in prompts) are processed by the vendor's infrastructure. GDPR lawful basis and a Data Processing Agreement are required.

→ Vendor change management
The vendor may update the model (change behaviour, capabilities, or safety properties) without adequate notice. You may be running a different model than you tested.

→ Logging and telemetry exposure
The vendor may log your inputs and outputs for safety monitoring, model improvement, or legal compliance. Review the vendor's data retention and logging policy explicitly — it is often not the default configuration you want.

→ Concentration risk
If this vendor is unavailable, what is the impact? For critical financial operations, single-vendor dependency on an AI API may be a DORA concentration risk.

→ Rate limits and cost
API rate limits can cause unexpected service degradation. Uncapped usage can produce material unexpected costs — both are operational risks.

KEY CONTROLS

✓ Data Processing Agreement covering inference data as GDPR personal data
✓ Model version pinning — use versioned API endpoints, not 'latest'
✓ Vendor security questionnaire (AI-specific TPRM extension)
✓ Logging configuration review — confirm what the vendor logs, for how long, and under what conditions
✓ Cost monitoring and rate limit alerting
✓ Concentration risk assessment and documented contingency

HOSTED ASSISTANT (ENTERPRISE AI TOOL / WORKSPACE)

End-users interact directly with a managed AI assistant — Microsoft Copilot, Google Gemini for Workspace, Slack AI, Notion AI, Salesforce Einstein. The vendor manages the model and application layer. Your organisation controls admin settings, user access, and policies.

Examples: Microsoft 365 Copilot, Google Gemini for Workspace, GitHub Copilot, Salesforce Einstein, ServiceNow Now Assist.

KEY RISKS

→ Shadow usage
Employees use AI tools without organisational awareness or control. Sensitive data shared with personal AI accounts is outside any organisational DPA.

→ Uncontrolled data sharing
Users share confidential documents, client data, or privileged communications with the AI system without considering data classification obligations.

→ Inconsistent user behaviour
Different users use the same tool in ways with very different risk profiles. Without guidance, policy, and monitoring, you cannot demonstrate consistent control outcomes.

→ Weak prompt and data handling hygiene
Users are unaware of what data the AI processes, retains, or shares. Clipboard content, document context, and conversation history may contain more sensitive data than the user intends.

→ Admin control gaps
Default settings for enterprise AI tools are often not the most restrictive. Features (web browsing, external sharing, plugin access) may be enabled by default.

KEY CONTROLS

✓ AI usage policy — define permitted and prohibited use cases and data types
✓ Approved tool list — only sanctioned AI tools should be used for work purposes; shadow AI policy
✓ User training — data classification awareness specific to AI usage
✓ Admin hardening — review and configure default settings; disable features not required
✓ Data loss prevention (DLP) integration — monitor for sensitive data in AI tool interactions
✓ Monitoring — AI tool usage logs, anomalous sharing patterns

SELF-HOSTED / PRIVATE MODEL

The model runs in your own environment — on-premises GPU infrastructure, a dedicated cloud tenant, or a private cloud deployment. You control the entire stack: model weights, serving infrastructure, networking, and access.

Examples: Llama 3 on private cloud, Mistral on on-premises GPU cluster, fine-tuned Qwen model on Azure private deployment, private Falcon deployment.

KEY RISKS

→ Model supply chain
Where did the model weights come from? Have they been verified? Open-source models distributed via Hugging Face can contain backdoors if the weights have been modified.

→ Infrastructure security
The model serving infrastructure is a privileged system. Access controls, network isolation, patching cadence, and incident response must be applied as for any critical system.

→ Operational maturity
Running LLM inference infrastructure requires significant ML engineering expertise. Inadequate operational maturity creates availability, integrity, and security risks.

→ No vendor support
Unlike hosted models, you own the problem entirely. There is no vendor to call when the model behaves unexpectedly, produces harmful outputs, or is exploited.

→ Model lifecycle
Patching, updating, or replacing a self-hosted model is entirely your responsibility. Clear model lifecycle processes are required.

KEY CONTROLS

✓ Model weight provenance verification (checksums against trusted sources)
✓ Infrastructure access controls (equivalent to critical system classification)
✓ Secure supply chain process for model updates and patches
✓ Operational runbooks for model serving, recovery, and incident response
✓ Internal red-teaming and safety evaluation before deployment

HYBRID WITH RAG (RETRIEVAL-AUGMENTED GENERATION)

The LLM is combined with a retrieval layer that queries internal documents, databases, or knowledge bases at inference time, injecting relevant context into the model's context window before generating a response. This is the dominant enterprise deployment pattern for knowledge-intensive use cases.

Examples: Internal policy Q&A systems, compliance research assistants, customer service bots drawing on knowledge bases, due diligence research tools.

KEY RISKS

→ Retrieval access control failures
Users retrieve documents from the knowledge base they are not authorised to access — the AI becomes a vector for unauthorised data access.

→ Prompt injection through documents
Malicious content in retrieved documents overrides system prompt instructions (indirect prompt injection).

→ Stale or poisoned knowledge bases
Outdated documents produce confidently wrong answers. Tampered documents spread systematic misinformation.

→ Context assembly risks
Combining system prompt + retrieved documents + conversation history creates a complex context that can exceed window limits, dilute safety instructions, or expose PII from retrieved sources.

KEY CONTROLS

✓ Document-level ACLs enforced at retrieval time
✓ Knowledge base ingestion governance (who can add documents, review process)
✓ Document versioning and expiry metadata
✓ Indirect prompt injection testing (adversarial documents in the knowledge base)
✓ Session isolation testing

TOOL / AGENT CALLING (LLM CAN TRIGGER EXTERNAL ACTIONS)

The LLM can call external tools or APIs — creating tickets, querying databases, sending emails, executing code, browsing the web, managing files. This transforms the model from a text generator into an autonomous agent capable of taking real-world actions with operational consequences.

Examples: AI coding assistants that commit code, AI email assistants that send messages, AI workflow automation that creates/closes tickets, multi-agent research pipelines, AI financial assistants that query live market data.

KEY RISKS

KEY CONTROLS

→ **Unauthorised actions**
The model takes actions the user or system prompt did not intend — via prompt injection, misunderstanding, or design flaws in the tool schema.

→ **Escalation of privileges**
A low-privilege user manipulates the model to take actions they could not take directly.

→ **Business logic abuse**
The model interprets instructions in ways that exploit edge cases in business rules or approval workflows.

→ **Irreversible harm**
Actions taken by the model — emails sent, records deleted, payments executed — cannot be undone without detection and explicit remediation.

→ **Weak approval boundaries**
Tool calls that should require human approval proceed automatically because approval gates are not implemented or are too permissive.

✓ Least privilege for all tool permissions
✓ Human-in-the-loop gates for irreversible actions
✓ Complete audit logging of all tool calls with stated model reasoning
✓ Scope limitations documented in system prompt and enforced at infrastructure level
✓ Tool call injection testing as part of pre-deployment security review

11. DATA FLOW — COMPLETE MAP WITH GOVERNANCE NOTES

Every stage of the LLM data flow produces both potential evidence (configurations, logs, test results you can show a regulator or auditor) and potential exposure (sensitive data, privileged actions, audit gaps). Mapping your data flow is not a technical documentation exercise — it is the foundation of your AI risk assessment and your evidence framework.

> GRC PRINCIPLE: Each stage of the data flow produces (a) evidence that can demonstrate control effectiveness, and (b) exposure that represents a risk requiring a control. Your governance framework must address both dimensions at every stage. A gap at any stage is either a missing control or a missing evidence requirement.

INPUTS	
User inputs	Free text, files, structured forms, voice transcripts. Contains the highest density of potentially sensitive, unstructured data. Users routinely include PII, commercial confidences, and privileged information in AI prompts without intending to — or without understanding the consequences.
System instructions	Policies, role constraints, persona definitions, and operational rules provided by the application layer (not by the user). These are the primary mechanism for controlling model behaviour. Their confidentiality, integrity, and completeness are critical governance variables.

PROMPT CONSTRUCTION	
Template assembly	The application layer combines the system prompt + user input + context policies into the prompt sent to the model. This assembly process is a critical governance point — it determines what the model sees, and in what order. Poor assembly can cause system prompt dilution, context overflow, or unintended data combination.
RAG injection (if applicable)	Retrieved document chunks are inserted into the assembled prompt, typically after the system prompt and before the user's query. The position, formatting, and delimitation of retrieved content significantly affect the model's handling of that content — and its vulnerability to indirect prompt injection.
Tool output injection (if applicable)	In agentic deployments, the outputs of previous tool calls are injected back into the context before the next generation step. Each tool output is a potential injection vector if it contains user-controlled or externally sourced content.

LLM PROCESSING	
Inference at provider or local	The assembled prompt is sent to the LLM inference engine — either a hosted provider API or a local model serving infrastructure. All content in the prompt is now visible to the inference engine and its logging infrastructure. This is the point at which your data governance obligations to the inference provider are most acutely relevant.
Output generation	The model generates a response token by token based on the assembled context and its training. At this stage, the model may reproduce training data (memorisation), combine context elements in unexpected ways, or follow injected instructions that override the intended system prompt.

OUTPUTS	
Response text	The primary output — the model's answer, draft, summary, classification, or instruction. Must pass through output filtering before delivery to the user. Should be treated as untrusted input to any downstream system (browser, database, API).
Citations (if implemented)	Source references attributed to retrieved documents. Must be verified — not assumed correct. Unverified citations are a hallucination risk that is invisible to the user because they look authoritative.
Structured outputs (JSON)	Machine-readable outputs for integration with downstream systems. Schema validation must be applied before processing. Malformed or unexpected JSON from the model can cause downstream system failures or injection vulnerabilities.
Tool calls (if enabled)	The model's instructions to invoke external tools or APIs. These are operational actions with real-world consequences. Must be logged, validated, and (for high-impact actions) gated on human approval before execution.

LOGS / TELEMETRY

Application logs	Prompts, outputs, tool calls, errors, user identities, session IDs, timestamps. The foundation of your audit trail and incident investigation capability. Must be immutable, complete, access-controlled, and retained for the period required by DORA and the EU AI Act.
Provider logs (if vendor-hosted)	The hosting provider may log inputs and outputs independently of your application logs. Review the provider's logging policy: what do they log, for how long, and can they use your data for model improvement? This is a GDPR and confidentiality concern requiring explicit DPA coverage.
Monitoring and telemetry	Real-time analysis of logs to detect: abuse signals (jailbreak attempts, sensitive data in prompts), policy violations (prohibited content in outputs), drift indicators (changes in output quality or safety properties), and anomalous tool call patterns. This is your primary ongoing control — not a retrospective audit function.

12. PRIMARY RISK CONCENTRATION POINTS

AI risks cluster in five domains: Confidentiality, Integrity, Availability, Compliance, and Safety (CIACS). Each domain contains specific risk scenarios relevant to LLM deployments in regulated financial services. Use this taxonomy to structure your risk assessment and to map your controls to specific risk scenarios.

CONFIDENTIALITY	
Sensitive data in prompts and attachments	Users routinely include PII, financial data, commercial confidences, privileged legal communications, and client information in prompts. The model processes and may reproduce this data in outputs or logs.
Sensitive data in retrieved documents (RAG)	Documents retrieved into the context window may contain sensitive data that the model then references, paraphrases, or quotes in its output — exposing that data to the user making the query.
Sensitive data in logs	Prompt logging (required for audit and monitoring) creates a store of potentially sensitive data that must be classified, access-controlled, and retained only for the minimum period required.
Unintended disclosure via outputs	The model may reproduce memorised training data, system prompt contents, or context window contents in its output — disclosing information to users who should not have access to it.
Disclosure via integrations and connectors	When AI systems are integrated with other tools (email, CRM, ticketing systems), outputs may be automatically shared to wider audiences than intended.

INTEGRITY	
Hallucinations driving wrong business decisions	Confident, plausible-sounding incorrect outputs used as the basis for regulated decisions — credit assessments, compliance judgments, risk ratings — without independent verification.
RAG knowledge base poisoning or staleness	Tampered or outdated documents in the knowledge base cause the model to systematically give wrong answers grounded in corrupted or obsolete source material.
Prompt injection — instruction override	Malicious inputs (from users or retrieved documents) cause the model to override its system prompt instructions, produce policy-violating outputs, or take unauthorised actions.
Output tampering in transmission	If outputs are transmitted without integrity controls, they could be modified between generation and delivery — causing the user to act on content that the model never generated.
Model drift	Model behaviour changes over time (due to provider-side model updates or distributional shift in inputs) without detection, causing the deployed system to behave differently from what was tested and approved.

AVAILABILITY	
Vendor outages and rate limits	Dependency on hosted AI providers creates availability risk. API rate limits can cause unexpected service degradation for legitimate users. For DORA-regulated entities, AI service outages may be ICT incidents.
Latency spikes	LLM inference latency is variable and can spike under load. For real-time use cases (fraud detection, customer service), latency spikes can have direct business impact.
Cost blowouts causing throttling or shutdown	Uncontrolled API usage — from adversarial DoS, usage growth, or runaway agentic workflows — can produce unexpected costs that force throttling or service shutdown.
Dependency failures	RAG systems depend on vector databases, embedding services, and document stores. Failures in any dependency degrade or disable the AI service even if the model itself is available.
Context window exhaustion	Very long conversations or very large retrieved documents can exhaust the context window, causing silent truncation of safety instructions or critical context.

COMPLIANCE	
Inadequate documentation and traceability	Cannot demonstrate to regulators what the system does, how it was tested, who approved it, and what controls are in place. EU AI Act and DORA both require documented evidence of controls.
DPIA / PIA gaps	AI systems processing personal data in novel ways (automated decision support, profiling, behavioural analysis) may require Data Protection Impact Assessments that have not been conducted.
Third-party risk gaps	AI vendors who process your data as sub-processors may not have adequate security posture, DPAs, data residency controls, or change notification procedures.

Retention control failures	Logs of prompts and outputs may be retained longer than required (GDPR data minimisation) or shorter than required (DORA 5-year retention, EU AI Act monitoring period). Both are compliance failures.
Inability to demonstrate control effectiveness	Controls exist but cannot be evidenced — monitoring dashboards, audit logs, testing results, and access reviews are not produced or maintained. Cannot pass audit.

SAFETY — POLICY, BRAND, AND LEGAL HARM	
Harmful content generation	The model produces content that is harmful, dangerous, offensive, or discriminatory — either because guardrails failed, were bypassed, or were never implemented for the use case.
Discrimination risk	AI systems used in regulated contexts (credit decisioning, hiring, insurance underwriting) may produce outputs that have a disparate impact on protected groups — creating legal exposure under EU AI Act high-risk provisions and existing discrimination law.
Unsafe operational guidance	The model provides guidance on physical, chemical, or procedural topics that could result in physical harm if followed — particularly in industries with safety-critical operations.
Internal misuse	Employees use the AI system to facilitate fraud, policy bypass, insider threats, or to exfiltrate data under the cover of legitimate-seeming AI interactions.
Regulatory liability from autonomous AI actions	In agentic deployments, actions taken by the AI system create legal and regulatory liability as if taken by an employee — but without the accountability clarity of a human actor.

13. CONTROL THEMES — PREVENT / DETECT / RESPOND

AI governance controls must be designed across three functions: preventing harmful events, detecting events that occur despite prevention controls, and responding effectively when incidents happen. A governance framework with only preventive controls has no visibility. A framework with only detective controls has no remediation capability. All three functions are required.

PREVENT — Controls that stop harmful events before they occur

Data Governance	
✓	Data classification rules for AI usage — which data types are permitted, which are prohibited, what redaction is required before including in prompts
✓	Prohibited data types list — PII categories, privileged communications, commercial confidences, client data that must not be included in AI prompts
✓	Retention limits for AI interaction logs — minimum required for DORA compliance, maximum required for GDPR data minimisation
✓	Data residency controls — ensure data is processed only in approved jurisdictions; relevant for vendor-hosted models

Access Control	
✓	SSO and MFA for all AI tool access — no shared accounts, no anonymous access
✓	Role-based access control (RBAC) — who can access which AI capabilities, with which tools, on which data
✓	Least privilege for tool permissions — each AI integration should have the minimum permissions required for its stated function
✓	Privileged tool approval gates — actions requiring elevated permissions (external communications, database writes, payment actions) require human approval before execution
✓	Connector scoping — AI system connections to enterprise data sources (email, CRM, document stores) should be scoped to the minimum access required

Prompt Governance	
✓	Approved prompt templates — pre-tested prompts for common use cases that have been validated for safety and policy compliance
✓	System prompt hardening — explicit, tested constraints against prohibited outputs, data disclosure, and policy violations
✓	Restricted tool schemas — tool definitions that expose only the operations the AI system is authorised to use
✓	Input validation — sanitisation of user inputs before prompt construction, detection of injection attempts

RAG Controls	
✓	Document access enforcement at retrieval — user identity must scope the retrieval query; not all documents should be retrievable by all users
✓	Ingestion approval process — documents added to the knowledge base must be approved by a document owner with subject matter expertise
✓	Content integrity checks — checksums or digital signatures on critical knowledge base documents; alerts on unauthorised modification
✓	Source allowlist — only approved, vetted sources should be eligible for ingestion into the knowledge base

Vendor Controls	
✓	Data Processing Agreements — covering inference data as GDPR personal data, with clear retention limits and prohibition on use for model training
✓	Contractual clauses on data use — prohibiting the vendor from using your data for model improvement without explicit consent
✓	Security posture requirements — vendor security certifications (SOC 2, ISO 27001) as minimum requirements
✓	Change management commitments — vendor must notify of material model updates with adequate lead time for regression testing

✓	Incident notification SLAs — vendor must notify you of security incidents affecting your data within defined timeframes

DETECT — Controls that identify events that slip through prevention

Monitoring	
✓	Prompt and output scanning for sensitive data — real-time detection of PII, financial data, or confidential information in AI interactions
✓	Policy violation detection — outputs that contain harmful content, prohibited information, or responses that violate system prompt constraints
✓	Jailbreak attempt detection — input patterns consistent with attempts to bypass system prompt instructions
✓	Anomalous tool call monitoring — tool invocations that are unusual in type, frequency, target, or parameter values
✓	Usage pattern anomaly detection — volume spikes, unusual user behaviour, access from unexpected locations

Logging	
✓	Immutable audit trails — all prompts, model parameters, retrieval sources, tool actions, and user identity logged to a tamper-evident store
✓	Complete context logging — sufficient detail to reconstruct the full context the model operated with at the time of any output — required for incident investigation
✓	Tool action logging — every external action taken by the model logged as if it were a privileged user action (equivalent audit trail to a human performing the same action)
✓	Session linkage — all log entries for a given user session linked by session ID to enable full session reconstruction

Quality Controls	
✓	Output evaluation metrics — hallucination rate, citation accuracy, policy compliance rate — tracked over time as KRIs
✓	Sampling and human review — periodic manual review of a sample of AI outputs to detect quality drift not caught by automated monitoring
✓	Drift monitoring — tracking changes in output quality, safety properties, or accuracy against ground truth over time
✓	Error and exception tracking — systematic recording of model errors, refusals, and unexpected outputs as quality signals

RESPOND — Controls that contain and remediate incidents

Incident Response Playbooks	
✓	Prompt injection / data leakage playbook — detection → containment (disable affected tool/connector) → investigation (identify scope of exposed data) → notification (GDPR Art. 33 if personal data; DORA incident classification if ICT impact) → remediation (patch system prompt or retrieval controls)
✓	Unsafe output playbook — detection → output suppression → root cause analysis (prompt failure? guardrail bypass? model behaviour change?) → system prompt or guardrail update → regression test before re-enabling
✓	Vendor outage playbook — detection → activate contingency capacity (alternative provider or reduced-service mode) → communication to affected users → vendor SLA enforcement → post-incident review
✓	Compromised knowledge base playbook — detection → isolate affected documents → assess scope of poisoning → notify affected users → remediate and re-validate knowledge base before restoring RAG capability

Kill Switches

✓	Disable individual connectors or tools — granular capability to remove specific tool access without disabling the entire system
✓	Restrict features — ability to reduce the system to a safe subset of capabilities (e.g. read-only, no tool calls) pending investigation
✓	Revert prompt templates — roll back to a known-good system prompt when a prompt change is implicated in an incident
✓	Roll back releases — ability to redeploy a previous version of the application layer if a new release introduces a safety regression
✓	Vendor killswitch — ability to redirect inference to an alternative provider or to disable the AI system entirely if the primary vendor is implicated in a security incident

Corrective Actions	
✓	User retraining — targeted training for users who have violated AI usage policy or demonstrated unsafe behaviour patterns
✓	Policy tightening — updating AI usage policy, system prompt constraints, or tool permission models in response to incident findings
✓	Baseline updates — revising risk acceptance thresholds, monitoring rules, or audit log requirements based on incident learnings
✓	Re-running assurance tests — full pre-deployment assurance evidence cycle after any significant corrective action — treat it as a new deployment from an assurance perspective

14. EVIDENCE FRAMEWORK — PRE-DEPLOYMENT AND ONGOING

For any AI deployment in a regulated environment, you must be able to produce evidence of controls — not just assert that controls exist. This section defines the complete evidence set required for pre-deployment sign-off and for ongoing operations. Use this as your AI assurance checklist.

Pre-deployment evidence — required before go-live

Evidence Item	What It Must Contain	Status
System architecture and data flow documentation	Full data flow including all components, third-party processing points, trust boundaries, and data classifications at each stage. A GDPR Article 30 record and an EU AI Act technical documentation requirement.	REQUIRED
Data classification and AI usage policy	What data is permitted and prohibited in AI prompts; retention and logging rules; prohibited use cases; consequences of policy violation. Must be communicated to all users before access is granted.	REQUIRED
Access control evidence	SSO/MFA configuration, RBAC configuration, connector scoping, admin role assignments, least privilege review results. Screenshot or configuration export evidence, not verbal assurance.	REQUIRED
Prompt and tool governance artifacts	Approved prompt templates with testing evidence, system prompt with adversarial test results, tool schemas with permission boundaries documented, approval gate design and testing.	REQUIRED
RAG evidence (if applicable)	Ingestion process documentation, retrieval access control configuration and test results, source allowlist, tamper detection controls, document versioning policy.	REQUIRED IF RAG
Security testing evidence	Red team results, prompt injection test suite and results, abuse scenario tests, sensitive data leakage tests. Must cover adversarial scenarios — benign testing is insufficient.	REQUIRED
Evaluation evidence	Acceptance thresholds for output quality metrics, test datasets used, human review process, documented known limitations and residual risk acceptance.	REQUIRED
Vendor assurance pack	Security documentation (SOC 2, ISO 27001 certs), incident response process, retention settings (confirmed, not default), change notification commitments. Do not rely on vendor websites — require documented commitments.	REQUIRED IF VENDOR-HOSTED
Operational readiness	Incident response playbooks specific to this AI deployment, monitoring dashboard configuration, escalation paths with named owners, kill switch procedures with tested exercise evidence.	REQUIRED
DPIA (if personal data processing)	Data Protection Impact Assessment where the AI processing is novel, large-scale, or uses special category data. Required by GDPR Article 35.	REQUIRED IF APPLICABLE

Ongoing operations evidence — continuous and periodic

Evidence Item	What It Must Contain	Cadence
Monitoring/KRI dashboard	Real-time metrics: policy violations, sensitive data detections, jailbreak attempt rate, anomalous tool calls, refusal rate. Trend view to show control effectiveness over time.	CONTINUOUS
Audit logs	Complete, immutable logs: user identity, session ID, timestamp, prompt (or hashed/redacted prompt per data minimisation), output, tool calls, retrieval sources, generation parameters. Retained for minimum required period.	CONTINUOUS
Periodic access reviews	Review of all user access, admin access, connector permissions, and tool access against current need and least-privilege standard. Minimum quarterly; more frequently for privileged access.	QUARTERLY
Model and provider change management	Release notes review for all model and provider updates, regression testing results before updates go to production, configuration drift checks, change records.	PER CHANGE
Evaluation cadence	Scheduled periodic re-testing of the AI system against the original acceptance criteria. Drift monitoring results. Post-incident revalidation after any significant incident.	QUARTERLY MINIMUM

Incident records	Detection events, triage decisions, containment actions, root cause analysis, corrective actions implemented, lessons learned, control improvements. Required for DORA compliance and EU AI Act post-market monitoring.	**PER INCIDENT**
Third-party review	Annual review of all AI vendor assurance documentation, DPA compliance, incident records, and change notifications received. Update TPRM risk ratings.	**ANNUAL MINIMUM**

Auditor and regulator questions — and the evidence that answers them

What the auditor / regulator asks	What evidence must be produced
Where does data go?	Data flow diagram + vendor processing boundaries confirmed in DPA + retention settings (provider logs, application logs) — evidence of each.
What data is prohibited and how is it enforced?	AI usage policy + technical controls (input validation, DLP integration) + monitoring evidence showing violations are detected and acted on.
Who can use it and what can it do?	RBAC configuration + connector scoping documentation + tool permission model + admin control evidence.
How do you prevent and detect prompt injection and data leakage?	Test plan + adversarial test results + monitoring configuration showing injection attempt detection + recent monitoring results.
How do you ensure output reliability for critical processes?	Evaluation framework + acceptance thresholds + human oversight workflow documentation + exception handling process.
How do you respond when it goes wrong?	Incident response playbooks + kill switch procedures + evidence of playbook exercise + incident log (with any past incidents).
How do you manage vendor and model changes?	Change control process + regression test evidence for recent model updates + vendor notification SLA evidence.
Can you prove control effectiveness over time?	KRI trend reports + audit log samples + periodic review records + corrective action records for any control failures found.

PRACTICAL GUIDANCE: The most common finding in AI governance reviews is not that controls are absent — it is that controls cannot be evidenced. A monitoring dashboard that no one looks at is not a control. A playbook that has never been exercised is not a control. An access review that is scheduled but never completed is not a control. Evidence of a control is proof that the control is operating effectively — not proof that it was designed.

15. EXTENDED GLOSSARY — 18 TERMS WITH GOVERNANCE CONTEXT

This glossary extends the core vocabulary from the earlier sections with additional terms commonly encountered in AI security and governance work. Each term includes its governance significance — not just its technical definition.

Term	Definition — with governance context
Token	A chunk of text the model processes — not always a full word. 'Unstructured' may be 2–3 tokens. Token count determines context window usage and API cost.
Context window	The maximum amount of text the model can 'see' at once — including system prompt, conversation history, retrieved documents, and tool outputs. Measured in tokens.
System prompt	The hidden, privileged instructions provided to the model before any user interaction. Defines the model's persona, permitted scope, and prohibited behaviours. Must be treated as a governed configuration item and a confidential trade secret.
Temperature	A parameter (0 to 2+) controlling the randomness of output token selection. Low temperature = more deterministic and consistent. High temperature = more varied and creative. A governance-relevant configuration parameter for regulated use cases.
Top-p (nucleus sampling)	An alternative randomness control that restricts the model to selecting only from the top-p probability mass at each token step. Often used in combination with temperature. Same governance implications.
RAG (Retrieval-Augmented Generation)	An architecture in which the model retrieves relevant document chunks from a knowledge base at query time and uses them to ground its response. Dominant enterprise deployment pattern. Introduces retrieval-layer-specific risks.
Vector database	A specialised database that stores high-dimensional numerical representations (embeddings) of document chunks and enables fast semantic similarity search. The retrieval engine for RAG systems.
Embedding model	A model that converts text into numerical vectors for storage and retrieval in a vector database. A separate component from the LLM itself. If the embedding model is updated, retrieval quality can degrade silently.
Prompt injection	A class of attacks in which malicious instructions are embedded in user input or retrieved content, causing the model to override its system prompt and take unintended actions. The primary application-layer security threat for LLMs.
Indirect prompt injection	A variant of prompt injection in which the malicious instructions are embedded in external content (a retrieved document, a web page, an email) rather than the user's direct input. Particularly dangerous in RAG systems.
Hallucination	A confident, plausible-sounding model output that is factually incorrect and not grounded in evidence. Fundamental property of LLMs — cannot be fully eliminated, only monitored and mitigated.
Tool / function calling	The model's ability to invoke external APIs or functions — enabling it to take real-world actions (send email, query database, create tickets). Transforms the model from a text generator into an agent with operational consequences.
Guardrails	Input and output processing layers that detect and block harmful, policy-violating, or off-topic content. A compensating control — not a primary control. Must be adversarially tested before deployment.
KRI (Key Risk Indicator)	A metric used to monitor risk levels over time. Examples for AI: hallucination rate, policy violation rate, jailbreak attempt rate, refusal rate, latency p99. KRIs are the foundation of your AI monitoring dashboard.
Model drift	Degradation of model performance over time as real-world data distribution diverges from training distribution. Can be sudden (external event) or gradual. Requires continuous monitoring to detect.
Fine-tuning	Retraining a pre-trained base model on a curated domain-specific dataset to adapt its behaviour for a specific task. Creates new data governance obligations (who owns the data, is PII included, who has the fine-tuning data).
DPIA (Data Protection Impact Assessment)	A GDPR Article 35 requirement for processing activities that are likely to result in high risk to individuals — including novel AI deployments processing personal data at scale. A governance gate before deployment.
Concentration risk	DORA concept: over-dependence on a single third-party provider for a critical ICT function. Applies to AI providers that are central to regulated financial operations.